WEB SECURITY CHALLENGE

Auditoría pasiva y activa con OWASP ZAP sobre Gin & Juice Shop

Julieth Linares

Hacker Women Council - Ethical Hacking

Octubre 2026

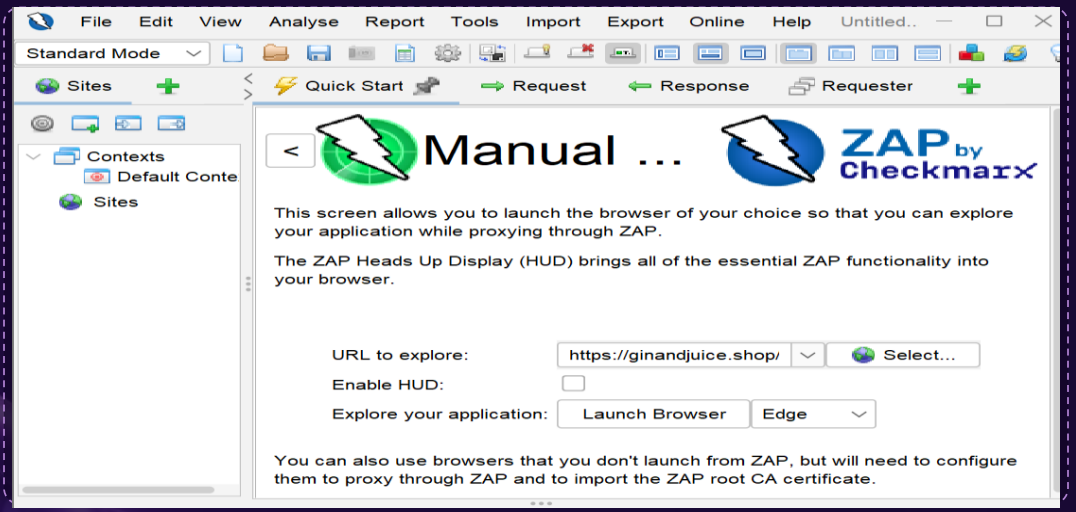


Preparación del entorno de pruebas

Elementos 1.1 y 1.2

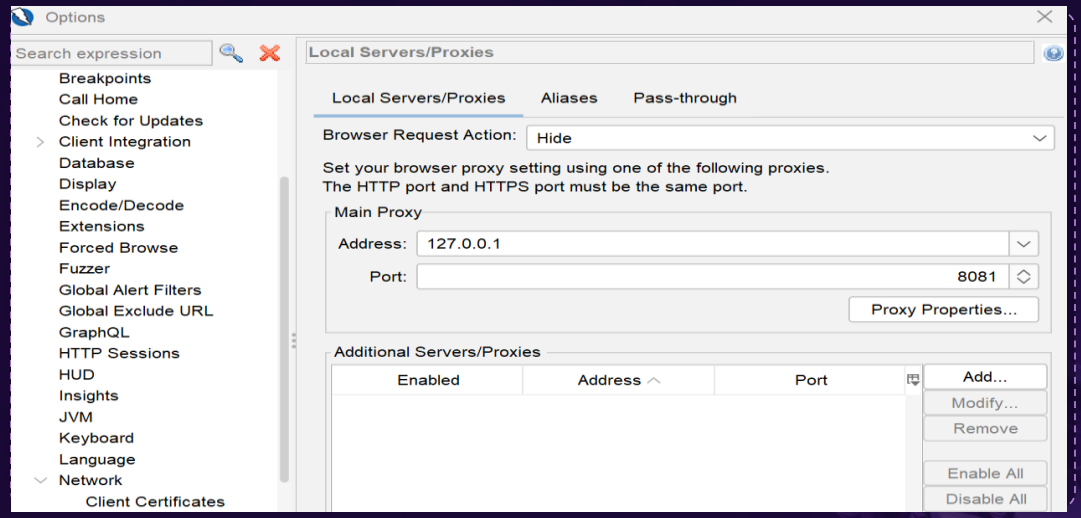
1.1 OWASP ZAP inicializado

Despliegue de la herramienta OWASP ZAP en el sistema local, verificando el correcto inicio del dominio y la disponibilidad de la interfaz principal de trabajo.



1.2 Configuración del proxy local

Ajuste del proxy manual en el navegador web apuntando a la dirección loopback 127.0.0.1 en el puerto 8080 para la captura del tráfico HTTP/HTTPS.

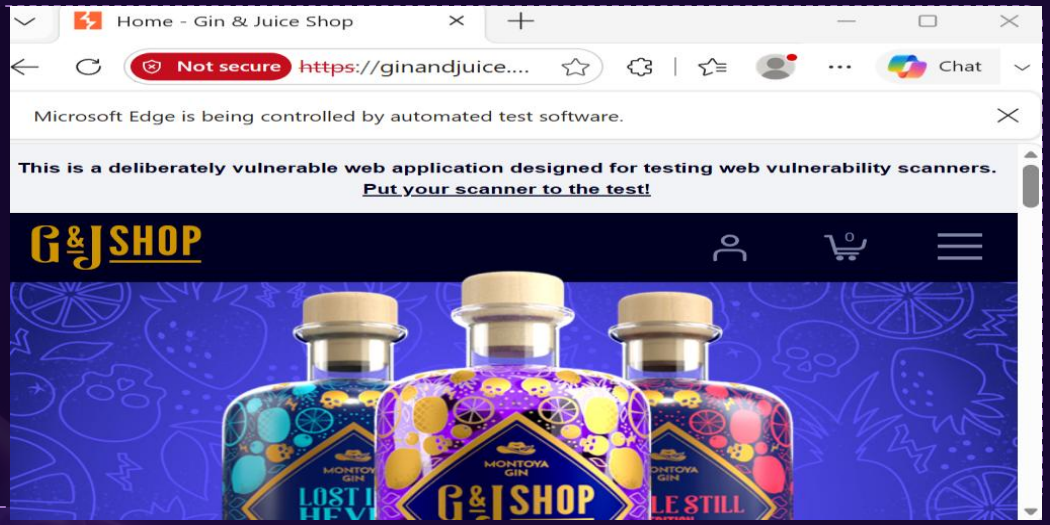


Preparación del entorno de pruebas

Elementos 1.3 y 1.4

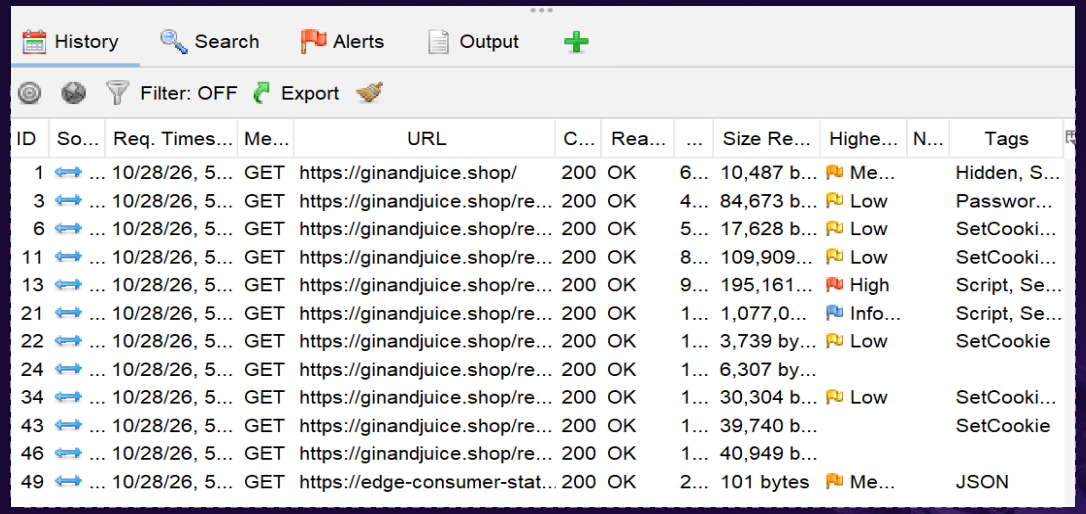
1.3 Acceso a la aplicación objetivo

Navegación directa hacia el dominio objetivo (https://ginandjuice.shop/) a través del navegador proxyficado para iniciar la sesión de auditoría.



1.4 Intercepción de tráfico en ZAP

Verificación en la pestaña “History” de OWASP ZAP, confirmando que las peticiones HTTP GET iniciales hacia el dominio son interceptadas correctamente.



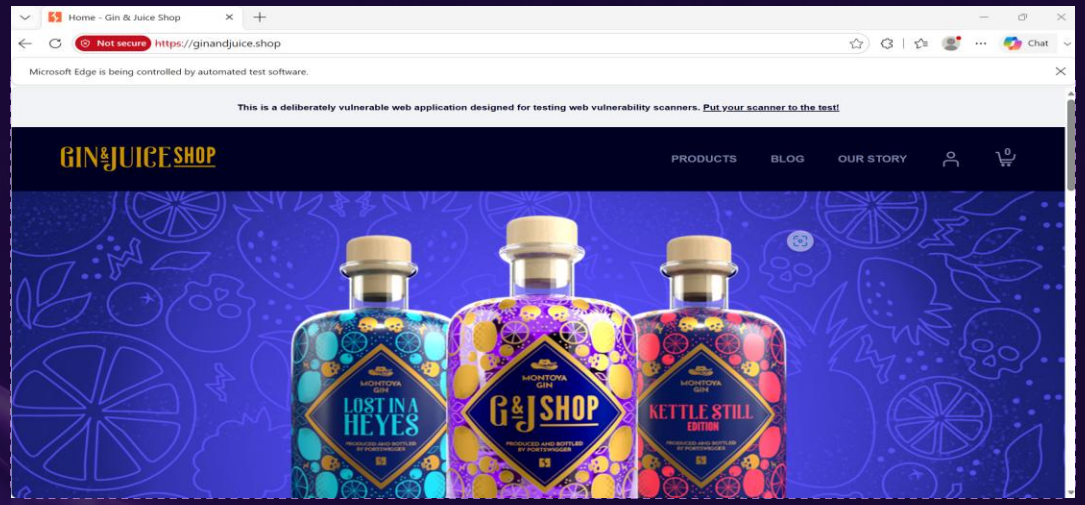
ID	So...	Req. Times...	Me...	URL	C...	Rea...	...	Size Re...	Highe...	N...	Tags
1	...	10/28/26, 5...	GET	https://ginandjuice.shop/	200	OK	6...	10,487 b...	Me...		Hidden, S...
3	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	4...	84,673 b...	Low		Passwor...
6	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	5...	17,628 b...	Low		SetCooki...
11	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	8...	109,909...	Low		SetCooki...
13	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	9...	195,161...	High		Script, Se...
21	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	1...	1,077,0...	Info...		Script, Se...
22	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	1...	3,739 by...	Low		SetCookie
24	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	1...	6,307 by...			
34	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	1...	30,304 b...	Low		SetCooki...
43	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	1...	39,740 b...			SetCookie
46	...	10/28/26, 5...	GET	https://ginandjuice.shop/re...	200	OK	1...	40,949 b...			
49	...	10/28/26, 5...	GET	https://edge-consumer-stat...	200	OK	2...	101 bytes	Me...		JSON

Exploración y mapeo de la aplicación

Elementos 2.1 y 2.2

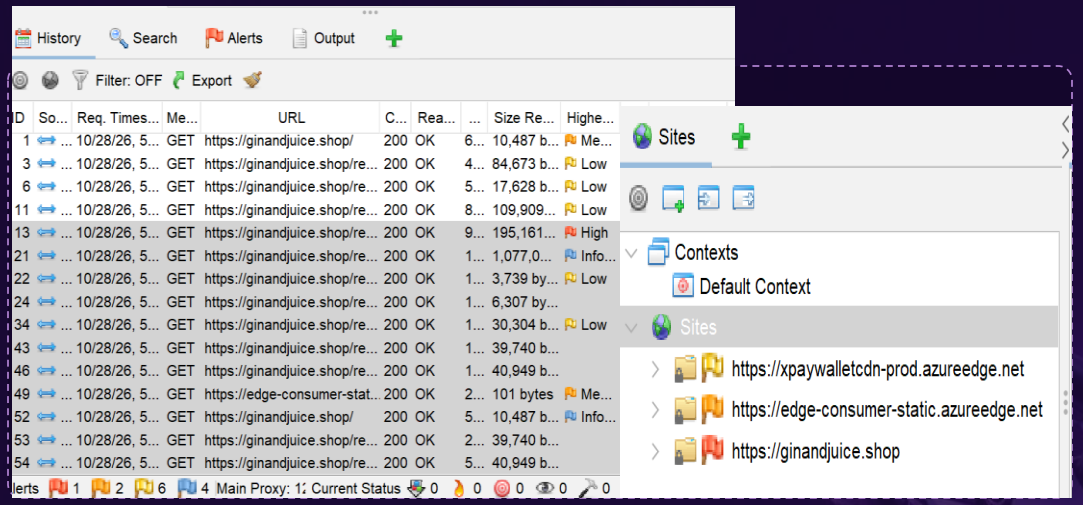
2.1 Navegación principal en el sitio

Recorrido inicial por la landing page de Gin & Juice Shop para permitir que el spider pasivo registre los recursos estáticos y dinámicos iniciales.



2.2 Mapeo de peticiones HTTP

Registro consolidado en el panel de ZAP que demuestra la captura de peticiones GET y POST correspondientes a las diferentes llamadas REST API del servidor.

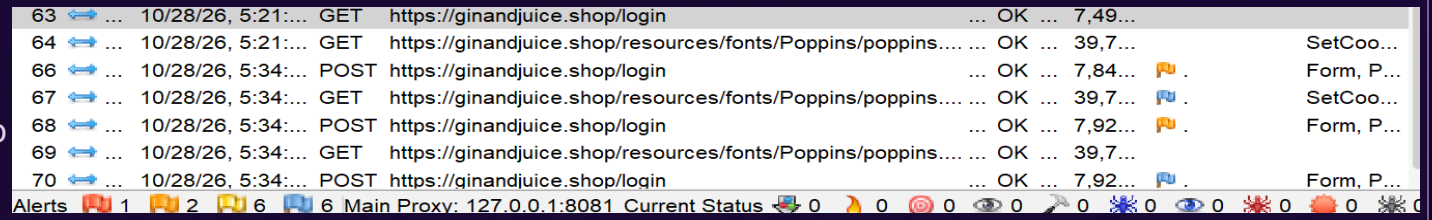


Exploración de secciones específicas

2.3

Módulo de inicio de sesión (Login)

Explora la interfaz de autenticación generando peticiones de validación de credenciales.



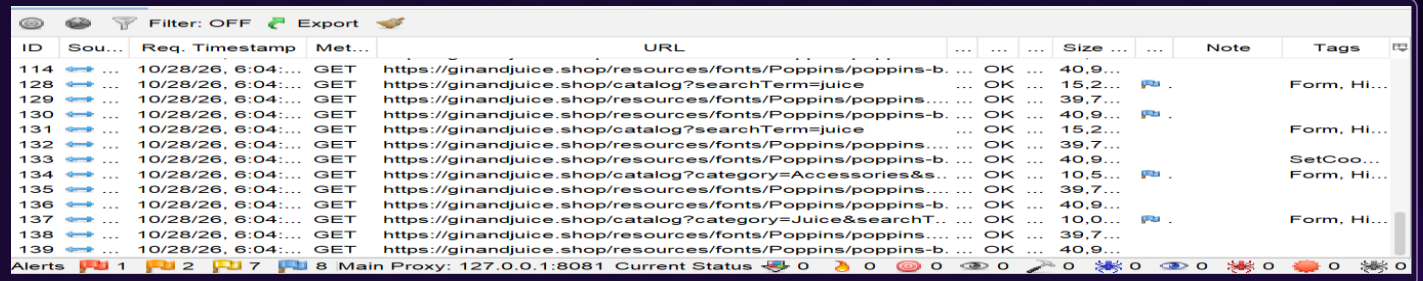
63	10/28/26, 5:21:...	GET	https://ginandjuice.shop/login	OK	7,49...			
64	10/28/26, 5:21:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	OK	39,7...			SetCoo...
66	10/28/26, 5:34:...	POST	https://ginandjuice.shop/login	OK	7,84...			Form, P...
67	10/28/26, 5:34:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	OK	39,7...			SetCoo...
68	10/28/26, 5:34:...	POST	https://ginandjuice.shop/login	OK	7,92...			Form, P...
69	10/28/26, 5:34:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	OK	39,7...			
70	10/28/26, 5:34:...	POST	https://ginandjuice.shop/login	OK	7,92...			Form, P...

Alerts 1 2 6 6 Main Proxy: 127.0.0.1:8081 Current Status 0 0 0 0 0 0 0 0 0 0

2.4

Búsqueda y catálogo de productos

Ejecución de búsquedas en el catálogo para auditar la transmisión de parámetros en las URL.



Filter: OFF Export

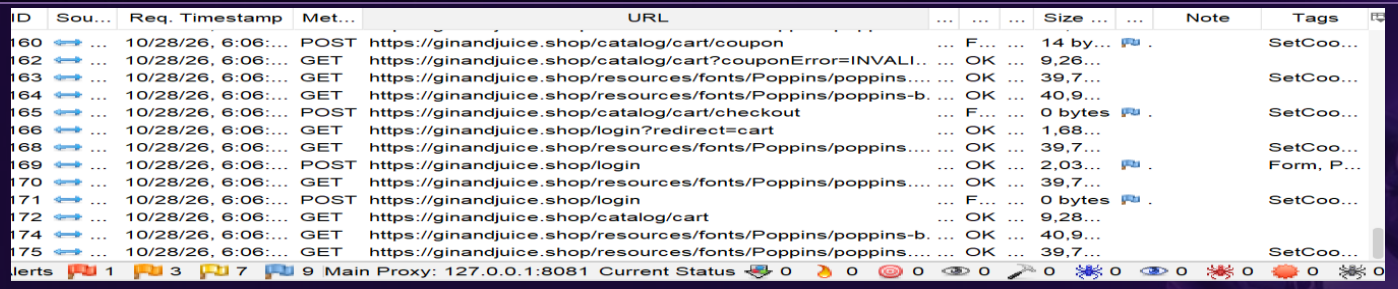
ID	Sou...	Req. Timestamp	Met...	URL	...	...	...	Size ...	...	Note	Tags
114	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins-b...	...	OK	...	40,9...			
128	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/catalog?searchTerm=juice	...	OK	...	15,2...			Form, Hi...
129	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	...	OK	...	39,7...			
130	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins-b...	...	OK	...	40,9...			
131	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/catalog?searchTerm=juice	...	OK	...	15,2...			Form, Hi...
132	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	...	OK	...	39,7...			
133	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins-b...	...	OK	...	40,9...			SetCoo...
134	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/catalog?category=Accessories&s...	...	OK	...	10,5...			Form, Hi...
135	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	...	OK	...	39,7...			
136	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins-b...	...	OK	...	40,9...			
137	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/catalog?category=Juice&searchT...	...	OK	...	10,0...			Form, Hi...
138	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	...	OK	...	39,7...			
139	...	10/28/26, 6:04:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins-b...	...	OK	...	40,9...			

Alerts 1 2 7 8 Main Proxy: 127.0.0.1:8081 Current Status 0 0 0 0 0 0 0 0 0 0

2.5

Perfil de usuario / Carrito

Navegación por áreas que gestionan estado y sesiones de usuario dentro de la plataforma.



ID	Sou...	Req. Timestamp	Met...	URL	...	...	...	Size ...	...	Note	Tags
160	...	10/28/26, 6:06:...	POST	https://ginandjuice.shop/catalog/cart/coupon	...	F...	...	14 by...			SetCoo...
162	...	10/28/26, 6:06:...	GET	https://ginandjuice.shop/catalog/cart?couponError=INVALI...	...	OK	...	9,26...			
163	...	10/28/26, 6:06:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	...	OK	...	39,7...			SetCoo...
164	...	10/28/26, 6:06:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins-b...	...	OK	...	40,9...			
165	...	10/28/26, 6:06:...	POST	https://ginandjuice.shop/catalog/cart/checkout	...	F...	...	0 bytes			SetCoo...
166	...	10/28/26, 6:06:...	GET	https://ginandjuice.shop/login?redirect=cart	...	OK	...	1,68...			
168	...	10/28/26, 6:06:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	...	OK	...	39,7...			SetCoo...
169	...	10/28/26, 6:06:...	POST	https://ginandjuice.shop/login	...	OK	...	2,03...			Form, P...
170	...	10/28/26, 6:06:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	...	OK	...	39,7...			
171	...	10/28/26, 6:06:...	POST	https://ginandjuice.shop/login	...	F...	...	0 bytes			SetCoo...
172	...	10/28/26, 6:06:...	GET	https://ginandjuice.shop/catalog/cart	...	OK	...	9,28...			
174	...	10/28/26, 6:06:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins-b...	...	OK	...	40,9...			
175	...	10/28/26, 6:06:...	GET	https://ginandjuice.shop/resources/fonts/Poppins/poppins....	...	OK	...	39,7...			SetCoo...

lerts 1 3 7 9 Main Proxy: 127.0.0.1:8081 Current Status 0 0 0 0 0 0 0 0 0 0

Análisis y clasificación de alertas de seguridad

ALTO / HIGH

SQL Injection (Inyección SQL)

Detección de parámetros vulnerables a la manipulación de consultas en la base de datos subyacente.

MEDIO / MEDIUM

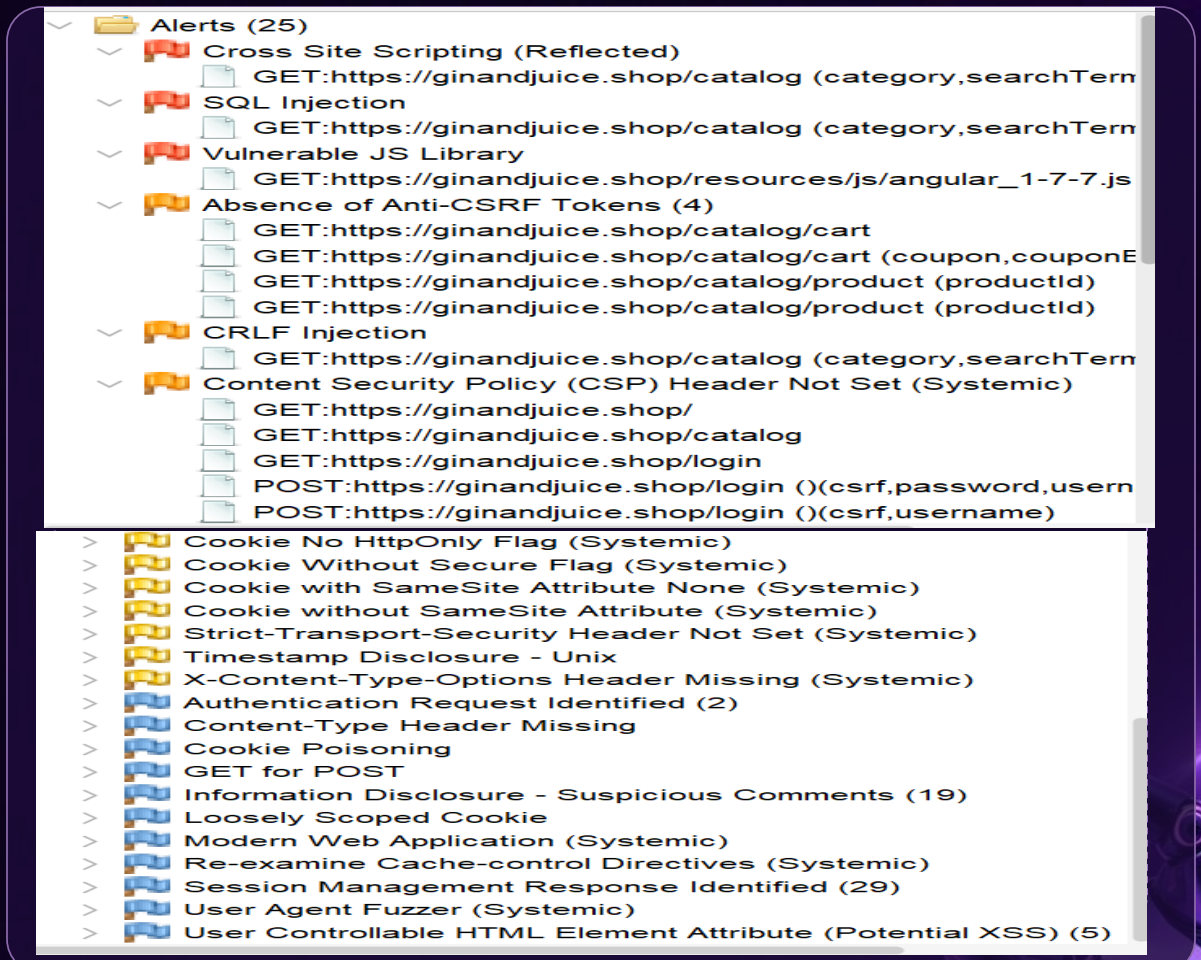
Absence of Anti-CSRF Tokens

Faltan tokens de protección contra falsificación de peticiones en sitios cruzados en los endpoints /catalog/cart y /catalog/product.

BAJO / INFO

Information Disclosure - Suspicious Comments

Se detectaron 19 comentarios sospechosos dentro del código HTML/JS que podrían exponer detalles internos o lógica de la aplicación web.



Ficha técnica del hallazgo principal

SQL Injection. URL, parámetro y payload aportados, pendientes de corroboración.

1. Nombre de la alerta

SQL Injection

2. Nivel de riesgo

ALTO / HIGH

3. URL / componente afectado

https://ginandjuice.shop/rest/products/search

4. Parámetro afectado: category

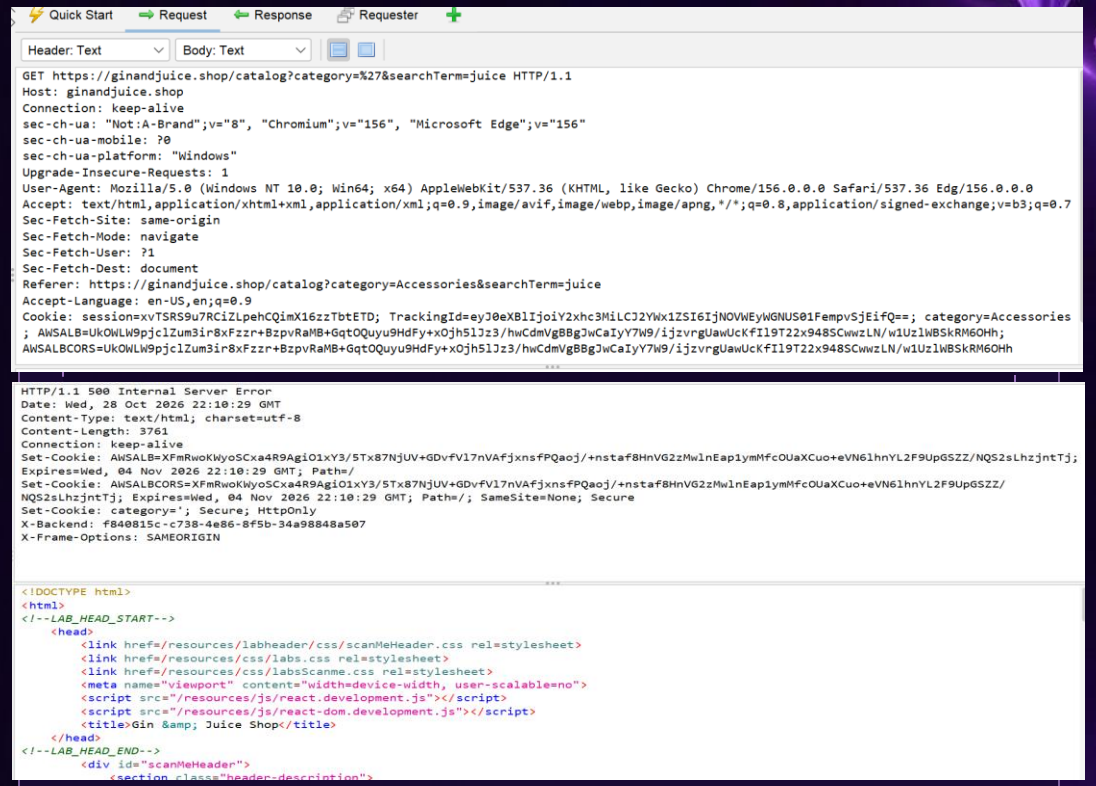
5. Payload: category=' *(o category=%27)*

6. Descripción técnica

La aplicación no valida ni sanitiza los caracteres especiales ingresados en el parámetro category dentro de la ruta /catalog. Al inyectar una comilla simple ('), la consulta SQL en el servidor se rompe, lo que genera una falla interna no controlada **HTTP 500 Internal Server Error**.

7. Impacto potencial

Extracción no autorizada de registros confidenciales del catálogo/base de datos, manipulación de consultas internas y posible evasión de mecanismos de autenticación y acceso.



8. Recomendación de remediación

Implementar consultas preparadas o parametrizadas (*Prepared Statements / ORM*), aplicar validación y sanitización estricta de tipos de datos en la entrada del usuario y configurar el manejo de errores para evitar exponer fallas HTTP 500.

Conclusiones y evaluación del laboratorio

Reflexión del laboratorio y cuadro resumen del reporte

¿Qué aprendí?

OWASP ZAP permite automatizar el mapeo de la superficie de ataque web, interceptar tráfico en tiempo real e identificar vulnerabilidades críticas mediante análisis pasivo y activo.

¿Qué fue lo más retador?

La resolución del conflicto de puertos al inicializar el proxy en ZAP (cambiando del puerto 8080 ocupado al 8081) y la localización analítica entre las 25 alertas detectadas para validar el fallo de SQL Injection en el parámetro category mediante la respuesta HTTP 500.

¿Qué revisaría a continuación?

Implementación de pruebas de control de acceso roto (BOLA/IDOR), auditoría de APIs con colecciones OpenAPI/Postman y verificación del cumplimiento contra la matriz de controles OWASP ASVS.

Resumen final del reporte

Clasificación referencial. Evidencia pendiente.

Risk Level	Name	URL	Parameter	Evidence
High	SQL Injection	https://ginandjuice.shop/catalog	category	HTTP 500 Internal Server Error (category=%27)
Medium	Cross-Site Scripting (XSS)	https://ginandjuice.shop/catalog	searchTerm	Payload reflejado en respuesta HTML
Informational	CSP / Anti-clickjacking	https://ginandjuice.shop/catalog	Formulario de carrito	Ausencia de tokens CSRF en POST/GET